



O-RAN.WG11.TR.CSM-Security-R004-v01.00

Technical Report

O-RAN Work Group 11 (Security Work Group)

Study on Continuous Security Monitoring

Copyright © 2025 by the O-RAN ALLIANCE e.V.

The copying or incorporation into any other work of part or all of the material available in this document in any form without the prior written permission of O-RAN ALLIANCE e.V. is prohibited, save that you may print or download extracts of the material of this document for your personal use, or copy the material of this document for the purpose of sending to individual third parties for their information provided that you acknowledge O-RAN ALLIANCE as the source of the material and that you inform the third party that these conditions apply to them and that they must comply with them.

O-RAN ALLIANCE e.V., Buschkauler Weg 27, 53347 Alfter, Germany
Register of Associations, Bonn VR 11238, VAT ID DE321720189

Contents

List of figures	5
List of tables	5
Foreword	6
Modal verbs terminology	6
Introduction	6
1 Scope	8
2 References	8
2.1 Normative references	8
2.2 Informative references	8
3 Definition of terms, symbols and abbreviations	9
3.1 Terms	9
3.2 Symbols	10
3.3 Abbreviations	10
4 Continuous security monitoring background, concept and assumptions	11
4.1 Background	11
4.2 Concept	12
4.3 Assumptions	13
5 Key Issues	13
5.1 Introduction	13
5.2 Key Issue #1: Data required to detect DDoS attacks	13
5.2.1 Introduction	13
5.2.2 Security threats	13
5.2.3 Potential security requirements	13
5.3 Key Issue #2: Data required to detect API security risks	14
5.3.1 Introduction	14
5.3.2 Security threats	14
5.3.3 Potential security requirements	14
5.4 Key Issue #3: Data required to detect cloud security risks	14
5.4.1 Introduction	14
5.4.2 Security threats	14
5.4.3 Potential Security Requirements	15
5.5 Key Issue #4: Data required to detect authentication attacks	15
5.5.1 Introduction	15
5.5.2 Security threats	15
5.5.3 Potential security requirements	15
5.6 Key Issue #5: Data required to detect compromised xApps	16
5.6.1 Introduction	16
5.6.2 Security threats	16
5.6.3 Potential security requirements	16
5.7 Key Issue #6: Data required to detect authorization attacks	16
5.7.1 Introduction	16
5.7.2 Security threats	16
5.7.3 Potential security requirements	17
5.8 Key Issue #7: Tampering with open-source software components	17
5.8.1 Introduction	17
5.8.2 Security threats	17
5.8.3 Potential security requirements	17
5.9 Key Issue #8: Data required to detect altered machine learning models used in Near-RT RIC	17
5.9.1 Introduction	17
5.9.2 Security threats	17
5.9.3 Potential security requirements	18

Deleted: 7

Deleted: 7

Deleted: 8

Deleted: 8

Deleted: 8

Deleted: 10

Deleted: 10

Deleted: 10

Deleted: 10

Deleted: 11

Deleted: 11

Deleted: 12

Deleted: 12

Deleted: 13

Deleted: 13

Deleted: 14

Deleted: 15

Deleted: 15

Deleted: 15

Deleted: 15

Deleted: 15

Deleted: 15

Deleted: 15

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 16

Deleted: 17

Deleted: 17

Deleted: 17

Deleted: 17

Deleted: 17

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 18

Deleted: 19

Deleted: 19

Deleted: 19

Deleted: 19

Deleted: 19

Deleted: 20

Deleted: 20

Deleted: 20

Deleted: 20

Deleted: 20

5.10	Key Issue #9: Standardized metadata for CSM	18
5.10.1	Introduction	18
5.10.2	Security threats	18
5.10.3	Potential security requirements	18
5.11	Key Issue #10: Data required to detect compromised ML data pipelining service used in Near-RT RIC	18
5.11.1	Introduction	18
5.11.2	Security threats	19
5.11.3	Potential security requirements	19
5.12	Key Issue #11: Compromised software delivery	19
5.12.1	Introduction	19
5.12.2	Security threats	20
5.12.3	Potential security requirements	20
5.13	Key Issue #12: Untrusted software dependencies	20
5.13.1	Introduction	20
5.13.2	Security threats	20
5.13.3	Potential security requirements	20
5.14	Key Issue #13: Adversarial attacks on AI/ML models	20
5.14.1	Introduction	20
5.14.2	Security threats	21
5.14.3	Potential security requirements	21
5.15	Key Issue #14: AI/ML-related data integrity and confidentiality	21
5.15.1	Introduction	21
5.15.2	Security threats	21
5.15.3	Potential security requirements	21
5.16	Key Issue #15: Model explainability and transparency	21
5.16.1	Introduction	21
5.16.2	Security threats	22
5.16.3	Potential security requirements	22
5.17	Key Issue #16 Model and data drift	22
5.17.1	Introduction	22
5.17.2	Security threats	22
5.17.3	Potential security requirements	22
5.18	Key Issue #17: Secure monitoring information sharing channels	22
5.18.1	Introduction	22
5.18.2	Security threats	22
5.18.3	Potential security requirements	23
5.19	Key Issue #18: Monitoring data ownership and privacy	23
5.19.1	Introduction	23
5.19.2	Security threats	23
5.19.3	Potential security requirements	23
6	Mitigations and solutions	24
6.1	Introduction	24
6.2	Solution #1: Data required for detecting DoS attacks due to flooding	24
6.2.1	General description	24
6.2.2	Impacts on existing interfaces and functionality	24
6.2.3	Solution evaluation	25
6.2.4	Potential security requirements	26
6.3	Solution #2: Data required to detect API security risks (DoS through resource consumption)	26
6.3.1	Introduction	26
6.3.2	Solution details	26
6.3.3	Evaluation	27
6.4	Solution #3: Continuous security monitoring for adversarial attacks on AI/ML models	27
6.4.1	Introduction	27
6.4.2	Solution details	27
6.4.3	Evaluation	28
6.5	Solution #4: Continuous security monitoring for AI/ML-related data integrity and confidentiality	28
6.5.1	Introduction	28
6.5.2	Solution details	28
6.5.3	Evaluation	28
6.6	Solution #5: Continuous security monitoring for software delivery	28

Deleted: 20

Deleted: 20

Deleted: 20

Deleted: 21

Deleted: 21

Deleted: 21

Deleted: 21

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 22

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 23

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 24

Deleted: 25

Deleted: 25

Deleted: 25

Deleted: 25

Deleted: 25

Deleted: 25

Deleted: 26

Deleted: 26

Deleted: 26

Deleted: 26

Deleted: 26

Deleted: 26

Deleted: 27

Deleted: 27

Deleted: 28

Deleted: 28

Deleted: 28

Deleted: 28

Deleted: 29

Deleted: 29

Deleted: 29

Deleted: 29

Deleted: 30

Deleted: 30

Deleted: 30

Deleted: 30

Deleted: 30

Deleted: 31

6.6.1	Introduction	28	Deleted: 31
6.6.2	Solution details	29	Deleted: 31
6.6.3	Evaluation	29	Deleted: 31
6.7	Solution #6: Continuous security monitoring for authentication attacks	29	Deleted: 31
6.7.1	Introduction	29	Deleted: 32
6.7.2	Solution details	29	Deleted: 32
6.7.3	Evaluation	31	Deleted: 32
6.8	Solution #7: Continuous security monitoring for authorization attacks	31	Deleted: 32
6.8.1	Introduction	31	Deleted: 33
6.8.2	Solution details	31	Deleted: 33
6.8.3	Evaluation	32	Deleted: 33
6.9	Solution #8: Continuous security monitoring for cloud attacks related to lateral movement	32	Deleted: 33
6.9.1	Introduction	32	Deleted: 34
6.9.2	Solution details	32	Deleted: 35
6.9.3	Evaluation	34	Deleted: 35
6.10	Solution #9: Detection and prediction of DoS attacks due to packet flooding using Density Based Clustering	34	Deleted: 35
6.10.1	Introduction	34	Deleted: 35
6.10.2	Solution details	34	Deleted: 35
6.10.3	Evaluation	36	Deleted: 36
7	Conclusions	36	Deleted: 36
7.1	Key issue to solution mapping	36	Deleted: 36
7.2	Recommendations	39	Deleted: 37
Annex:	Change history/Change request (history)	41	Deleted: 38
			Deleted: 39
			Deleted: 39
			Deleted: 42
			Deleted: 44

List of figures

Figure 4.1-1 - Continuous security monitoring and related ZTA tenet.....	12	Deleted: 14
Figure 4.2-1 - Continuous security monitoring cycle	12	Deleted: 14
Figure 6.10-1 - Diagram illustrating burst of packets	35	Deleted: 37
Figure 6.10-2 - Overall system level view of DBC implementation	35	Deleted: 38

List of tables

Table 6.2.2-1 - Data for statistical analysis	25	Deleted: 27
Table 6.2.2-2 - Data for security events (alarms/logs)	25	Deleted: 27
Table 6.2.2-3 - Data for configuration	25	Deleted: 28
Table 6.2.4-1 - Data for standardization	26	Deleted: 28
Table 6.3.2-1 - O-RAN API DoS Unique ID	26	Deleted: 28
Table 6.3.2-2 - Example data associated with O-RAN API DoS resource consumption	27	Deleted: 29
Table 6.6.2-1 - Data for software validation during onboarding	29	Deleted: 29
Table 6.7.2-1 - Security logs for authentication attacks	30	Deleted: 29
Table 6.8.2-1 - Security logs for authorization attacks	31	Deleted: 31
Table 6.9.2-1 - Security logs for cloud attacks related to lateral movement	33	Deleted: 32
Table 6.10.2-1 - Example description of clusters exceeding threshold	35	Deleted: 34
Table 6.10.3-1 - Mapping of key issues to Solutions	37	Deleted: 35
		Deleted: 38
		Deleted: 40

Foreword

This Technical Report (TR) has been produced by O-RAN Alliance.

The content of the present document is subject to continuing work within O-RAN and may change following formal O-RAN approval. Should the O-RAN Alliance modify the contents of the present document, it will be re-released by O-RAN with an identifying change of version date and an increase in version number as follows:

version xx.yy.zz

where:

- xx: the first digit-group is incremented for all changes of substance, i.e. technical enhancements, corrections, updates, etc. (the initial approved document will have xx=01). Always 2 digits with leading zero if needed.
- yy: the second digit-group is incremented when editorial only changes have been incorporated in the document. Always 2 digits with leading zero if needed.
- zz: the third digit-group included only in working versions of the document indicating incremental changes during the editing process. External versions never include the third digit-group. Always 2 digits with leading zero if needed.

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the O-RAN Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in O-RAN deliverables except when used in direct citation.

Introduction

In the evolving landscape of telecommunications, the Open Radio Access Network (O-RAN) architecture has emerged as a game-changer, promising unprecedented flexibility, interoperability, and innovation. However, with this new level of openness and diversity comes an expanded attack surface and heightened security challenges. To address these concerns, continuous security monitoring is imperative for O-RAN networks to ensure their resilience and protect sensitive data.

This technical report delves into the intricacies of continuous security monitoring for O-RAN, exploring the key principles, technologies, and best practices that enable effective security posture management. By providing a comprehensive overview, we aim to empower stakeholders—including telecom operators, vendors, and security experts—with the knowledge necessary to safeguard O-RAN networks against evolving threats.

We will delve into the practical aspects of implementing continuous security monitoring, data collection strategies, and the integration of security monitoring solutions within the O-RAN ecosystem.

Lastly, we will discuss the future outlook for continuous security monitoring in O-RAN, considering emerging technologies, standards, and regulatory frameworks that will shape the landscape. By embracing a proactive and adaptive security posture, O-RAN networks can harness the full potential of openness and innovation while maintaining the highest levels of security and reliability.

This technical report serves as a valuable resource for anyone involved in the design, deployment, or security management of O-RAN networks, offering a comprehensive understanding of continuous security monitoring practices.

1 Scope

The present document presents the Continuous Security Monitoring study as it applies to O-RAN architectural elements.

Taking into consideration the threats and risks identified in O-RAN Threat Modeling and Risk Assessment [i.2], the study analyzes a list of key issues on abnormal security events and proposes solutions in order to derive security requirements, intended to be part of O-RAN Security related Specifications.

2 References

2.1 Normative references

Not applicable.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies. In the case of a reference to a 3GPP document, a non-specific reference implicitly refers to the latest version of that document in Release 18, or the latest 3GPP release prior to Release 18 that includes that document.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, O-RAN cannot guarantee their long term validity.

The following referenced documents are not necessary for the application of the present document but they assist the user with regard to a particular subject area.

- [i.1] 3GPP TR 21.905: "Vocabulary for 3GPP Specifications".
- [i.2] O-RAN ALLIANCE TR: "O-RAN Security Threat Modeling and Risk Assessment".
- [i.3] O-RAN ALLIANCE TS: "Security Requirements and Controls Specifications".
- [i.4] "Nokia Threat Intelligence Report 2023": <https://www.nokia.com/networks/security-portfolio/threat-intelligence-report/>.
- [i.5] "OWASP Top 10 API security risks": <https://owasp.org/API-Security/editions/2023/en/0x00-header/>.
- [i.6] NIST Special Publication 800-207, "Zero Trust Architecture", August 2020, <https://doi.org/10.6028/NIST.SP.800-207>
- [i.7] "UNICC Cyber Threat Landscape Report 2023": May 2024.
- [i.8] OWASP Top 10:2021: "A07:2021 – Identification and Authentication Failures", https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/.
- [i.9] O-RAN ALLIANCE TR: "Study on Security for Near Real Time RIC and xApps".
- [i.10] OWASP Top 10:2021: "A01:2021 – Broken Access Control"; https://owasp.org/Top10/A01_2021-Broken_Access_Control/.
- [i.11] "MITRE ATT&CK": <https://attack.mitre.org/>.
- [i.12] O-RAN ALLIANCE TR: "Security Log-Management".

- [i.13] NIST special publication 800-137: “Information Security Continuous Monitoring for Federal Information Systems and Organizations”.
- [i.14] O-RAN ALLIANCE TS: “Near-RT RIC Architecture”.
- [i.15] ITU Data Communications Networks Information Technology – Open Systems Interconnection – Systems Management: “Security Alarm Reporting Function Recommendation X.736”; <https://www.itu.int/rec/T-REC-X.736-199201-1/en>.
- [i.16] Bernhard Scholkopf et al: “Support Vector Method for Novelty Detection”; https://proceedings.neurips.cc/paper_files/paper/1999/file/8725fb777f25776ffa9076e44fcd776-Paper.pdf.
- [i.17] “Hasan Torabi et al: Practical autoencoder based anomaly detection by using vector reconstruction error”; <https://cybersecurity.springeropen.com/articles/10.1186/s42400-022-00134-9>.
- [i.18] IEEE Xplore: “Network Intrusion Detection in Cloud Computing Environments”; <https://ieeexplore.ieee.org/document/10731075>.
- [i.19] O-RAN ALLIANCE TR: “Study on Zero Trust Architecture for O-RAN”.
- [i.20] NIST Special Publication 800-207A, "A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments", September 2023
<https://doi.org/10.6028/NIST.SP.800-207A>
- [i.21] O-RAN ALLIANCE WID: “O-RAN-WID-WG11-2024-CSM-Proposal for Continuous Security Monitoring”, [WID-Proposal for Continuous Security Monitoring-v01.00 - Security Work Group - Confluence](#)

3 Definition of terms, symbols and abbreviations

3.1 Terms

Void.

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the abbreviations given in [i.1] and the following apply:

API	Application Programming Interface
CCPA	California Consumer Privacy Act
CNF	Containerised Network Function
CPU	Central Processing Unit
CSM	Continuous Security Monitoring
CVE	Common Vulnerabilities Exposures
DADPF	DDoS Analytics, Detection and Prediction Function
DBC	Density Based Clustering
DoS	Denial of Service
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
NF	Network Function
SMO	Service and Managment Orchestration
UNICC	United Nations International Computing Centre
VNF	Virtualised Network Function
ZTA	Zero Trust Architecture

4 Continuous security monitoring background, concept and assumptions

4.1 Background

NIST SP 800-207 [i.6] defines a Zero Trust Architecture (ZTA) to protect against internal threats. ZTA does not assume trust for any subject requesting resources, whether the subject is internal or external. ZTA also assumes that an adversary is already present inside the network. There is also a new publication on zero trust access control in cloud environments NIST SP 800-207A [i.20] that extends the zero trust principles to make an access control model for cloud-based workloads.

The ZTA WI TR [i.19] recommends to have a dedicated WI for CSM elaborating Tenet 5 and Tenet 7 applying to O-RAN.

As shown in Figure 4.1-1, Tenets 5 and 7 of ZTA is as below:

[ZT-5]: The enterprise monitors and measures the integrity and security posture of all owned and associated assets. No asset is inherently trusted.

[ZT-7]: The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to improve its security posture.

In order for enterprises to monitor and measure the integrity and security posture of an O-RAN deployment, it is important to define and collect security data (e.g. security alarms, security logs, security counters) from all O-RAN components, including O-RU, O-DU, O-CU, Non-RT RIC.

The Open Radio Access Network (O-RAN) ALLIANCE is an industry consortium focused on developing open interfaces for radio access networks. The alliance's vision is to enable a more dynamic, flexible, and secure network infrastructure through open interfaces, interoperability, and collaboration between vendors. As part of this vision, there is a need for the O-RAN architecture to support continuous security monitoring capabilities.

Objectives:

1. Study the security related data from O-RAN architectural elements to assess security events including abnormal events related to potential attacks.
2. Study the security data obtained from O-RAN architectural elements which are related to non-O-RAN architectural elements (e.g. UEs) to assess security events including abnormal events related to potential attacks.
3. Provide guidelines for the use of the collected security related data for:
 - a) Defining the security posture,
 - b) Mitigating the attack,
 - c) Enforcing the security policy.
4. Provide guidelines to address
 - a) The integration of external threat intelligence sources,
 - b) The integration with other O-RAN work items,
 - c) Orchestration related to continuous security monitoring.
5. Monitor the work of 3GPP on the topic of CSM to consider their study in O-RAN.

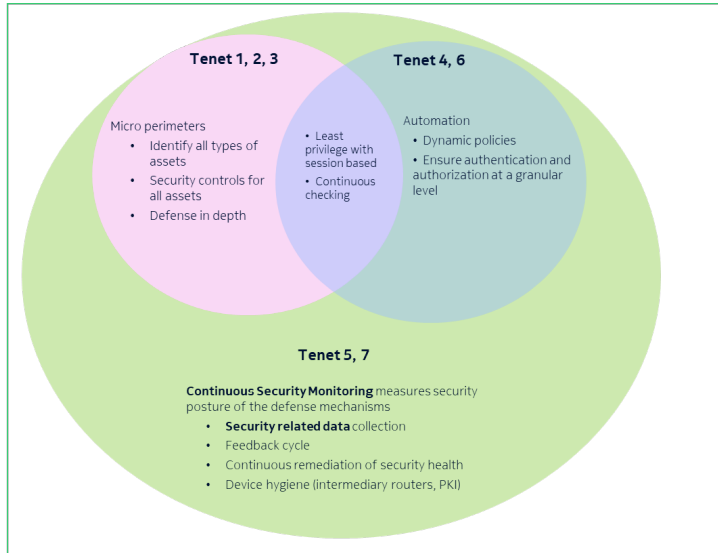


Figure 4.1-1 - Continuous security monitoring and related ZTA tenet

4.2 Concept

The scope of this study is primarily to focus on the enablers for continuous security monitoring as in Figure 4.2-1 which is the security related data to be defined and collected as agreed in [i.21]. Other aspects of Tenet 5 and Tenet 7 related to security posture, enforcement of security policy may be mentioned purely as guidelines.

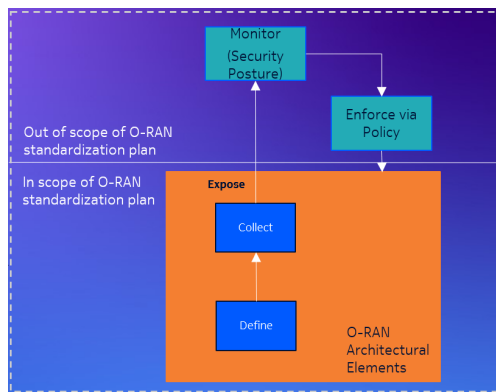


Figure 4.2-1 - Continuous security monitoring cycle

4.3 Assumptions

The assets will be inherited from the ZTA technical study [i.19].

The threats will also be reused from the existing threats and risk analysis document in [i.1].

Exposing the security data in a structured manner can help to automate the continuous security monitoring. In order to do this, classification of security data and defining a structure can help.

In this TR we explore what type of data has to be defined and collected to support CSM.

5 Key Issues

5.1 Introduction

In this clause, the key issues will be introduced, and respective security threats and potential security requirements will be identified related to continuous security monitoring.

5.2 Key Issue #1: Data required to detect DDoS attacks

5.2.1 Introduction

According to Nokia Threat Intelligence Report 2023 [i.4], 60% of attacks in telecom mobile networks are linked to Internet of Things (IoT) bots scanning for vulnerable hosts to expand their botnets for use in distributed denial-of-service (DDoS) attacks. Various kinds of DDoS attacks are known and published on the internet. Some DDoS attacks can be launched by flooding a system or component with a lot of packets, while other kinds of DDoS attacks use system vulnerabilities like buffer overflow, and some other attacks use un-handled error scenarios to bring down the availability of the system or a component.

It is important to distinguish between a DDoS attack and a system issue (like performance issues). The security evaluation and monitoring systems require the correct set of data to perform this distinction accurately. Attackers may be passively monitoring the system or a component for some time before launching active DDoS attacks. Data collected during the phase of passive monitoring can also be useful to clearly detect a DDoS attack instead of mis-interpreting system un-availability as a software issue.

5.2.2 Security threats

If relevant data is not collected, DDoS attacks cannot be detected in an effective way. Effects of successful DDoS attacks may be mistaken with system (performance) issues or with effects of other types of attacks. Due to ineffective attack type triage, the appropriate mitigation actions against a DDoS attack may not be executed by the operator.

DDoS attacks may affect the O-RAN architectural elements. Hence, all O-RAN architectural elements can be considered as potentially impacted by such an attack.

5.2.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect potential DDoS attacks on any O-RAN architectural element.

5.3 Key Issue #2: Data required to detect API security risks

5.3.1 Introduction

According to O-RAN architecture, CNFs and VNFs provide the necessary functionalities in NFs including O-DU, O-CU, SMO, Near-RT-RIC, Non-RT-RIC, etc. O-Cloud provides the platform for these NFs. Each NF is likely to expose one or more APIs (internally or externally) for interactions with other NFs. OWASP top 10 API security risks are detailed in [i.5]. Also, literature talks about Reverse engineering attacks, API spoofing, adversary-in-the-middle attacks and replay attacks as other kinds of attacks on APIs.

For CSM, it is important for the O-RAN architecture elements to be able to collect necessary data in order to determine if any malicious actor is attempting to exploit any of the API security vulnerabilities. Considering the fact that almost all NFs in O-RAN are expected to implement APIs, this is very important from the perspective of ZTA.

5.3.2 Security threats

If relevant data is not exposed to assess the potential exploitation of API security risks, attacks may go unnoticed, and operators may not be able to take mitigation steps. Malicious actors may be able to compromise confidentiality, integrity and availability of the system without getting detected.

All O-RAN interfaces which expose APIs can be impacted by such attacks.

5.3.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect/predict potential exploitation of API security risks.

5.4 Key Issue #3: Data required to detect cloud security risks

5.4.1 Introduction

According to the United Nations International Computing Centre (UNICC) the largest strategic partner for digital solutions and cybersecurity within the United Nations, cloud related threats are on the rise since 2023. In the majority of cases analyzed and handled by UNICC in [i.7], adversaries deployed malware on the compromised host as a primary action following the initial compromise. Once the cyber-attacker has compromised the secured system, they are able to execute additional malicious code to make unauthorized attempts to collect intelligence from cloud resources.

One of the recommendations from UNICC is to implement continuous monitoring capabilities which would enable the organizations to identify, respond to, and mitigate cyber threats at an early stage, enhancing overall cybersecurity resilience. Hence the need to collect and monitor data related to cloud security threats.

5.4.2 Security threats

If relevant data is not exposed to assess the potential exploitation of cloud network functions it poses a severe security risk, as the compromised element may be used by the attackers to target other subsystems residing in the cloud infrastructure. Without proper monitoring, operators may not be able to take mitigation steps. Malicious actors may be able to compromise confidentiality, integrity and availability of the system without getting detected. Security threats related to cloud include (but are not limited to): exploitation of vulnerable software, unauthorized access as in [i.6], lack of authentication & authorization in interfaces between cloud components, unsecured credentials and keys, sensitive application data cache exploitation and numerous threats specific to all cloud related technologies (e.g. threats specific to VMs, containers or hardware).

O-RAN network functions operating in a cloud infrastructure can be impacted by such attacks as cloud environments are prone to security vulnerabilities, which can expose sensitive customer data, critical network configurations, and traffic data to cyberattacks. These kinds of attacks can result in service outages, financial loss, and regulatory fines.

Another risk related to cloud environments is the fact that they might introduce higher latency, which can degrade the performance of latency-sensitive telecom network functions. This is important as attackers are often abusing compromised cloud environments to misuse resources, which could have effect on the performance of network functions.

One more risk is related to deployments of networks which could be using public cloud infrastructures and share resources with other cloud users, leading to potential issues with performance isolation, security vulnerabilities, or contention for resources.

Cloud related risks could further include attacks related to data breaches, resource abuse, lateral movement, denial of service due to NF unavailability as described in [i.11].

5.4.3 Potential Security Requirements

O-RAN system should be able to expose necessary data which can be used to analyse and detect/predict potential threats related to cloud security risks.

5.5 Key Issue #4: Data required to detect authentication attacks

5.5.1 Introduction

Authentication is a critical factor in implementing a ZTA for O-RAN architectural elements. It is essential that the O-RAN maintains robust security in this area, as inadequate authentication can lead to loss of customer trust and have significant impacts on an operator's financial health, overall reputation, and regulatory compliance. According to OWASP, authentication-related threats are among the top security concerns [i.8].

These threats can affect various elements, including identification from cloud-based services, edge devices, and remote API clients. In O-RAN, authentication can be achieved through multiple methods such as password-based systems, certificate-based authentication (including mutual TLS), token-based authentication as part of OAuth2.0 framework, and 802.1x based port authentication.

A few of the authentication related threats related to O-RAN are T-O-RAN-03, T-O-RAN-05, T-O-RAN-06, T-NEAR-RT-03, T-rAPP-04, T-rAPP-06, T-R1-03, T-A1-01, T-E2-01, T-Y1-01, T-GEN-02, T-GEN-04, T-GEN-05, T-GEN-06, T-SMO-01, T-SMO-04, T-SharedORU-01, T-SharedORU-03, as identified in [i.2].

5.5.2 Security threats

If the relevant security data related to capturing authentication workflows is not exposed, then there are chances that external and internal attacks will go undetected leading to sabotage of the O-RAN network.

The O-RAN architectural elements support authentication on various O-RAN interfaces with protocols including HTTP, mTLS, IPsec, IEEE 802.1x, SSH, SCTP, as in [i.3].

The possibility of threats relates to unauthenticated access to O-RAN functions, improper authentication mechanisms, use of predefined/ default accounts, weak or missing password policy, brute-force as in [i.2], obtaining of client secrets, improper extraction of certificates, and session management attacks.

5.5.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect potential authentication attacks on any O-RAN architectural element or interface.

5.6 Key Issue #5: Data required to detect compromised xApps

5.6.1 Introduction

xApps on the Near-RT RIC collect near real-time information from E2 nodes and can influence their behaviour, which impacts cell performance and the delivery of services to individual users or groups of users [i.9]. However, vulnerable, and exploitable xApps can be compromised by attackers, potentially disrupting network services in various ways. Several vulnerabilities can lead to the compromise of an xApp, including security misconfigurations, weak or improperly configured authentication and authorization mechanisms, and the presence of backdoors intentionally inserted by a trusted source [i.9].

5.6.2 Security threats

Failure to collect relevant data can result in compromised xApps going undetected, preventing operators from taking necessary mitigation actions.

A compromised xApp has the potential to access and manipulate sensitive subscriber data, putting their privacy at risk and negatively affecting the performance of the RAN and the core network. Moreover, such an xApp could interfere with the delivery of services to subscribers or even take control of another xApp or the Near-RT RIC, increasing security risks within the system [i.9].

5.6.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect compromised xApps.

5.7 Key Issue #6: Data required to detect authorization attacks

5.7.1 Introduction

Access Control was among the more common of OWASP's Top 10 risks to be involved in exploits and security incidents indicating that 'Broken Object Level Authorization' has been the most common and impactful attack on APIs [i.10]. The potential impact resulting from exploitation of authorization flaws is highly variable, both in form and severity. Attackers may be able to read, create, modify, or delete resources that were meant to be protected (thus jeopardizing their confidentiality, integrity, and/or availability); however, the actual impact of such actions is necessarily linked to the criticality and sensitivity of the compromised resources. Thus, the business cost of a successfully exploited authorization flaw can range from very low to extremely high.

Authorization is a critical factor in implementing a ZTA for O-RAN architectural elements. It is essential that the O-RAN continuously validates the authorization for every resource and every action performed that is technically possible. Even if the application implements a proper infrastructure for authorization checks, developers might forget to use these checks before accessing a sensitive object. Unauthorized access can result in data disclosure to unauthorized parties, data loss, or data manipulation.

A few of the authorization related threats related to O-RAN are T-O-RAN-05, T-O-RAN-06, T-O-RU-04, T-NEAR-RT-04, T-R1-01, T-R1-04, T-AppLCM-04, T-GEN-04, T-GEN-05, T-GEN-06, T-VM-C-01, T-VM-C-05, T-ADMIN-02, T-SMO-02, T-SMO-05, T-SMO-18, T-SharedORU-22, as identified in [i.2].

5.7.2 Security threats

If the relevant security data related to capturing authorization workflows is not exposed, then there are chances that external and internal attacks will go undetected leading to sabotage of the O-RAN network due to horizontal privilege elevation (i.e. being able to access another user's resources). Faults related to authorization control can allow malicious insiders and outsiders alike to view, modify, or delete sensitive resources of all forms or perform actions, such as creating a new account that they should not be privileged to do.

The O-RAN architectural elements support authorization on various O-RAN interfaces with protocols including HTTP, mTLS, IPSec, SSH, SCTP, as in [i.3].

The possibility of threats relates to unauthorized access to O-RAN functions, manipulation of data, misconfiguration, violation of the principle of least privilege, etc.

5.7.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect potential authorization attacks on any O-RAN architectural element or interface.

5.8 Key Issue #7: Tampering with open-source software components

5.8.1 Introduction

The O-RAN architecture elements relies on open-source software components, which can be vulnerable to tampering by malicious actors. An attacker could intentionally introduce vulnerabilities or backdoors into the open-source code, compromising the security of the entire system.

5.8.2 Security threats

Tampering with open-source software components can lead to the introduction of malicious code, which can be used to gain unauthorized access, disrupt system operation, or steal sensitive information (MITRE ATT&CK [i.11] technique T1195: Supply Chain Compromise).

Malicious code can also be used to create a backdoor, allowing attackers to maintain access to the system even after the initial vulnerability has been patched (MITRE ATT&CK technique T1098: Account Manipulation).

5.8.3 Potential security requirements

Continuous monitoring of open-source software components for suspicious activity or anomalies.

5.9 Key Issue #8: Data required to detect altered machine learning models used in Near-RT RIC

5.9.1 Introduction

Some xApps hosted on the Near-RT RIC incorporate machine learning (ML) solutions for inference and/or training. These ML-enabled xApps can integrate necessary models directly or access them from databases or separate filesystems/storage. When ML models are embedded within xApps, they may be compromised due to vulnerabilities within the xApp itself or weaknesses in exposed APIs. On the other hand, for xApps utilizing models stored externally in a database or separate storage, compromises may occur due to vulnerabilities that lead to unauthorized updates in the database, weaknesses in database security, or inadequate authentication and authorization measures for the database [i.9].

5.9.2 Security threats

Failure to collect relevant data can result in altered ML models going undetected, preventing operators from taking necessary mitigation actions.

An attacker may gain unauthorized access to a machine learning model and modify its parameters, affecting the accuracy of its outputs. This can lead to incorrect predictions, potentially resulting in catastrophic outcomes if these predictions inform critical business decisions. Additionally, attackers can extract sensitive or confidential data embedded within the ML model through training [i.9].

5.9.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect altered ML models.

5.10 Key Issue #9: Standardized metadata for CSM

5.10.1 Introduction

This key issue is to develop standardized metadata to support CSM in O-RAN. Standardized metadata is required to enable multi-vendor interoperability for all types of data collected to support CSM with automation. As a result, security analytics functions can effectively conduct analytics leveraging the data collected regardless of which vendor solution is used to collect the data.

The following provides more information for this key issue by partially leveraging Key Issue SLF#1: Standardized logging metadata in SLM to support security analytics, as defined in clause 5.4.1 of [i.12]. Key Issue SLF#1 in SLM provides a good baseline for standardized logging metadata only for security event type. However, there are additional data types that need to be considered. Other examples of data types that are not covered by SLM may include performance data, KPIs, vulnerability scanning and patch management information, intrusion detection and prevention system information, malware detection data, asset management data, configuration management data, license and information management information, software assurance data, network monitoring data, and alarms. Refer to Appendix D of [i.13] for details on continuous security monitoring data collection methods.

5.10.2 Security threats

CSM will collect various types of data from O-RAN architecture elements and interfaces. Security analytics functions need to conduct analytics on the data and correlate the data to detect security threats. For security analytics functions to consume the data collected regardless of which vendor solution is used to collect the data, it will be essential to have standardized metadata for CSM. If the metadata is not standardized across various security related data, then this would impede interoperability.

5.10.3 Potential security requirements

The metadata of the data collected for security evaluation and monitoring should be standardized to support robust and interoperable security analytics.

5.11 Key Issue #10: Data required to detect compromised ML data pipelining service used in Near-RT RIC

5.11.1 Introduction

The Near-RT RIC data pipelining service facilitates data ingestion and preparation for xApps within the Near-RT RIC platform [i.14]. The inputs to the data pipelining service may include:

- E2 node data collected via the E2 interface [i.14].
- Enrichment information transmitted over the A1 interface [i.14].

- Data provided by xApps [i.14].
- Data retrieved from the Near-RT RIC database through the messaging infrastructure [i.14].

The output of the Near-RT RIC data pipelining service consists of datasets that are prepared for consumption by AI/ML models. These datasets may be:

- Stored in an xApp-specific space (e.g. a dedicated database), where they can be accessed later for training or inference [i.14].
- Used directly as input for inference [i.14].

The ML data pipelining service may be vulnerable to compromise through several attack vectors. These include vulnerabilities within the xApp that utilizes the ML data pipelining service itself. Additionally, the service could be targeted by poisoning attacks originating from compromised E2 nodes or compromised UEs. Further risks arise from the potential compromise of databases that store historical data consumed by the data pipelining service. Furthermore, malicious actors could gain unauthorized access through compromised interfaces of the Near-RT RIC [i.9].

5.11.2 Security threats

Failure to collect relevant data can result in compromised ML data pipelining service used in Near-RT RIC going undetected, preventing operators from taking necessary mitigation actions.

An attacker gaining unauthorized access to the machine learning data pipelining service could take control of a subset of the training data by inserting or modifying training samples [i.2]. This could undermine:

- The integrity of the training or test data.
- The integrity of the trained ML model.
- The accuracy and reliability of the ML prediction results derived from the model.
- The overall behaviour and performance of the ML system.

NOTE: This key issue is related to key issue #14 and key issue #15.

5.11.3 Potential security requirements

O-RAN architecture elements should be able to expose necessary data which can be used to analyse and detect compromised ML data pipelining service used in Near-RT RIC.

5.12 Key Issue #11: Compromised software delivery

5.12.1 Introduction

The O-RAN architecture elements software delivery process can be compromised by malicious actors, allowing them to inject malicious code or modify legitimate code to include vulnerabilities.

NOTE: While being an important aspect of the software lifecycle, software delivery is not fully covered in O-RAN specification at the time of publication. However, security requirements of important aspects of it can be found in [i.3], clause 5.3.2.

5.12.2 Security threats

Compromised software delivery can lead to the introduction of malicious code, which can be used to gain unauthorized access, disrupt system operation, or steal sensitive information (MITRE ATT&CK [i.11] technique T1195: Supply Chain Compromise).

Attackers can also use compromised delivery processes to create a backdoor, allowing them to maintain access to the system even after the initial vulnerability has been patched (MITRE ATT&CK [i.11] technique T1098: Account Manipulation).

5.12.3 Potential security requirements

The O-RAN architecture elements should support continuous security monitoring of software delivery processes for detecting and preventing suspicious activity.

5.13 Key Issue #12: Untrusted software dependencies

5.13.1 Introduction

The O-RAN architecture elements relies on third-party software dependencies, which can be untrusted or vulnerable to exploitation by malicious actors. An attacker could exploit vulnerabilities in these dependencies to gain access to the system or disrupt its operation.

NOTE: for an example of security related aspects of third-party software dependencies in O-RAN, see [i.2], thread T-AIML-SC-06.

5.13.2 Security threats

Untrusted software dependencies can introduce vulnerabilities, which can be exploited by attackers to gain unauthorized access, disrupt system operation, or steal sensitive information (MITRE ATT&CK [i.11] technique T1195: Supply Chain Compromise).

Attackers can also use vulnerabilities in dependencies to create a backdoor, allowing them to maintain access to the system even after the initial vulnerability has been patched (MITRE ATT&CK [i.11] technique T1098: Account Manipulation).

5.13.3 Potential security requirements

The O-RAN architecture elements should support continuous security monitoring of software dependencies for detecting and preventing vulnerabilities.

NOTE: vulnerable 3rd party package testing is very important but is outside the scope of the O-RAN ALLIANCE.

5.14 Key Issue #13: Adversarial attacks on AI/ML models

5.14.1 Introduction

O-RAN architecture elements may utilize AI/ML for various functions, including network optimization and anomaly detection. However, the use of AI/ML models introduces new security risks, particularly the threat of adversarial attacks. Adversarial attacks may involve manipulating the input data to AI/ML models to cause misclassifications or incorrect decisions, potentially leading to security breaches or disruptions to network operations.

5.14.2 Security threats

Adversarial attacks on AI/ML models can be launched by sophisticated attackers using techniques such as data poisoning, model inversion, or evasion attacks.

Attackers may exploit vulnerabilities in AI/ML models to compromise the integrity of network optimization and anomaly detection functions, leading to potential security breaches or disruptions to network operations.

5.14.3 Potential security requirements

The O-RAN architecture elements should support continuous security monitoring of AI/ML models and datasets to detect and prevent adversarial attacks.

5.15 Key Issue #14: AI/ML-related data integrity and confidentiality

5.15.1 Introduction

AI/ML models in O-RAN architecture elements rely on large datasets for training and operation. However, the collection, storage, and transmission of these datasets introduce risks related to data integrity and confidentiality. If an attacker gains unauthorized access to or manipulates the datasets, it can compromise the accuracy and reliability of AI/ML models.

5.15.2 Security threats

Unauthorized access or manipulation of AI/ML-related data leads to the following security threats:

- Data Manipulation (MITRE ATT&CK [i.11] T1565): Adversaries can alter the dataset to introduce biases or errors.
- Data Exfiltration (MITRE ATT&CK [i.11] TA0010): Sensitive data can be leaked, leading to privacy breaches and potential exploitation.
- Content Injection (MITRE ATT&CK [i.11] T1659): Malicious data can be injected into the dataset to compromise the model's performance.

5.15.3 Potential security requirements

The O-RAN architecture elements should support continuous security monitoring of events related to data storage and transmission to detect and prevent unauthorized access or manipulation of AI/ML-related data.

5.16 Key Issue #15: Model explainability and transparency

5.16.1 Introduction

AI/ML models used in O-RAN networks can be complex and difficult to interpret, making it challenging to understand their decision-making processes. This lack of transparency and explainability can make it difficult to detect and respond to potential security threats.

5.16.2 Security threats

The lack of transparency and explainability in AI/ML models can make it challenging to detect and respond to potential security threats, potentially leading to delayed or inadequate incident response (MITRE ATT&CK [i.11]: T1406 - Obfuscated Files or Information).

Attackers may exploit the lack of transparency and explainability to launch attacks that are difficult to detect or attribute.

5.16.3 Potential security requirements

The O-RAN architecture elements should support continuous security monitoring of AI/ML model performance and events related to model performance to detect and respond to potential security threats.

The O-RAN architecture elements should support continuous security monitoring of AI/ML model decision-making processes to detect and respond to potential security threats.

5.17 Key Issue #16 Model and data drift

5.17.1 Introduction

Model and data drift can occur over time, leading to degraded performance of AI/ML models. Continuous monitoring is necessary to detect and address drift to maintain the effectiveness of network optimization and anomaly detection.

5.17.2 Security threats

Model and data drift leads to the following security threats:

- Concept Drift: Changes in the underlying data distribution can lead to model inaccuracies.
- Data Drift: Changes in the input data characteristics can affect model performance.
- Model Drift: The model's predictions may become less accurate over time due to changes in the environment.

5.17.3 Potential security requirements

The O-RAN architecture elements should support continuously monitor model performance metrics to detect and address drift.

5.18 Key Issue #17: Secure monitoring information sharing channels

5.18.1 Introduction

Establishing secure channels for information exchange, transporting security monitoring data, is crucial for effective security monitoring in the O-RAN ecosystem. These channels must ensure the confidentiality, integrity, and availability of shared security data and threat intelligence.

5.18.2 Security threats

Insecure information sharing channels cause the following security threats:

- Unauthorized access to sensitive information: An attacker could intercept or exploit vulnerabilities in the information sharing channels, gaining access to sensitive security data or threat intelligence.
- Data tampering: An attacker could modify or manipulate the shared information, compromising its integrity and potentially leading to incorrect security decisions.
- Eavesdropping: An attacker could intercept and listen to sensitive information shared between stakeholders, compromising confidentiality.
- Denial of Service (DoS) Attacks: Disrupting the availability of information exchange channels.

5.18.3 Potential security requirements

The O-RAN architecture elements should establish secure information sharing channels by the following means:

- Support end-to-end encryption for all information shared between stakeholders.
- Establish access controls, including authentication and authorization, to ensure only authorized entities can access shared information.
- Support data integrity checks to detect any tampering or modifications.
- Support redundant communication channels and failover mechanisms to maintain availability.

5.19 Key Issue #18: Monitoring data ownership and privacy

5.19.1 Introduction

Addressing privacy and data ownership concerns is essential to ensure that shared information is used appropriately and complies with regulatory requirements. This involves defining and implementing clear policies and procedures for data handling and access control.

5.19.2 Security threats

Not implementing clear policies and procedures for data handling and access control causes the following security threats:

- Unauthorized Access: Unauthorized parties gaining access to sensitive data.
- Data Misuse: Authorized users misusing shared data for unintended purposes.
- Regulatory Non-Compliance: Failure to comply with data protection regulations such as GDPR or CCPA.
- Insider Threats: Malicious insiders exploiting their access to sensitive information.

5.19.3 Potential security requirements

The O-RAN architecture elements should implement the following policies and procedures for data handling and access control:

- Establish clear data ownership and usage policies, defining what data can be shared, with whom, and under what conditions.
- Implement data anonymization or pseudonymization techniques to protect sensitive information.
- Ensure compliance with relevant regulations, such as GDPR, CCPA, or HIPAA, when handling and sharing sensitive data.

- Define and enforce data handling and storage standards for all stakeholders.
- Regularly review and update data sharing agreements to ensure they remain relevant and effective.

6 Mitigations and solutions

6.1 Introduction

In this clause, the solutions will be introduced, and respective solution details and possible evaluation means will be described.

6.2 Solution #1: Data required for detecting DoS attacks due to flooding

6.2.1 General description

This solution proposes a DoS attack detection and prevention function that collects data from all architectural elements in O-RAN to determine whether a DoS attack might be occurring. The DoS attack that is mitigated by this solution is the packet flooding variation of a DoS attack. Only rate-based DoS attacks are covered by this solution.

Implementations of the DoS detection and prevention functionality may vary, but this application should include following functionalities to mitigate the risks of DoS attacks:

- Data should be collected from all architectural elements in O-RAN (e.g.: O-RU, O-CU, and O-DU) to detect DoS attacks across the entire network.
 - The data that each architectural element provides can include the element identification information, number of packet bursts that are above a configured threshold, and packet origin.
 - A log will also be provided which has detailed information about the data provided by each element.
 - The data can also include alerts which are when number of packet bursts exceed the preconfigured threshold.

6.2.2 Impacts on existing interfaces and functionality

Any NF should provide data that can indicate a potential DoS attack caused by packet flooding.

The data that should be provided can be grouped into three categories: data for statistical analysis, data for security events (alarms/logs), and data for configuration as indicated in **Error! Reference source not found.**

One procedure to detect DoS attacks related to packet flooding is counting the number of packets and detecting the source of the largest number of packets.

Table 6.2.2-1 - Data for statistical analysis

DoS Packet Flooding Metrics	Description	Examples
NF ID	Unique identification for an O-RAN architectural element instance	O-CU_ID
Interface ID	Unique identification for an interface	O-CU_F1U_ID
Number of packets received	A counter related to DoS packet flooding attack detection using TCP/IP packets	3 (an integer [0..n])
Origins for the largest number of packets.	Source IP addresses of the largest number of TCP/IP packets	<ip_addresses>

Table 6.2.2-2 - Data for security events (alarms/logs)

Category	Data	Example
Alarm	Alarm information Source IP Destination IP Probable cause (Denial of Service due to packet flooding) (an operational violation event as referred to in section 8.1.2.1 of [i.15])	DDoS_packet_flooding_alarm_ID
Logs	Time Unique ID Source IP Destination IP	DoS_packet_flooding

Table 6.2.2-3 - Data for configuration

Configurations for DoS Packet Flooding Data Collection	Examples
Threshold for counters (e.g.:<number of packets/<time period>)	1000/s
Threshold that raises an alarm Alarm_DDoS_Packet_Flooding	Alarm is active if the counter measured is above the threshold

6.2.3 Solution evaluation

This solution addresses the Key Issue “Data Required for DDoS Attacks”. This solution enforces the requirement from the Key Issue regarding obtaining data from all O-RAN architectural elements. By gathering needed data from all O-RAN architectural elements, there will be insight into whether a DoS attack due to packet flooding is occurring.

6.2.4 Potential security requirements

The O-RAN NFs should be able to expose necessary data which can be used to analyse and detect potential DoS attacks due to packet flooding on any O-RAN architectural element. The data that should be standardized includes the following: parameters for configuration, unique IDs for alarms/logs, and counter nomenclature and definition and is described in Table 6.2.4-1.

Table 6.2.4-1 - Data for standardization

Data Type	Description
Parameters for Configuration	Parameters for configuration (thresholds for counters and alarms)
Unique Identification Descriptions for Alarms and Logs	Unique ID for alarms and logs
Counter Nomenclature	The counter names
Counter Definition	Definition for counters that indicate number of packets per time period

6.3 Solution #2: Data required to detect API security risks (DoS through resource consumption)

6.3.1 Introduction

Key Issue #2 “Data required to detect API security risks” describes the risks for APIs in the O-RAN architecture. The particular API security risk addressed in this solution is Denial-of-Service (DoS) due to unrestricted resource consumption. The API security risk from the OWASP API Security Top 10 project [i.5] addressed in this solution is API4:2023 Unrestricted Resource Consumption for APIs. An O-RAN architecture element may provide an API for communication and access to hosted services. An adversary may attempt to disrupt operations and degrade network performance by sending an overwhelming number of requests within a short period of time to execute a Denial-of-Service (DoS) attack. Detection of an API DoS attack through resource consumption depends upon the ability to collect information on resource consumption and API request messages.

The data may be collected internally by the O-RAN architecture elements, for example by the SMO, or a dedicated network function, or externally by a pre-existing system deployed by the operator.

6.3.2 Solution details

This type of monitored attack can be assigned and tagged with a unique ID derived from associated API security risk from [i.5]:

Table 6.3.2-1 - O-RAN API DoS Unique ID

Type of Attack	O-RAN Unique ID
O-RAN API DoS Resource Consumption	API_OWASP2023_4_RESOURCE

The Table 6.3.2-2 below provides examples of data to be collected to detect an API DoS attack through resource consumption.

Table 6.3.2-2 - Example data associated with O-RAN API DoS resource consumption

Data Type	Example Events or Items of Interest
Resource utilization	Above average utilization of resources such as memory, and compute
API requests/responses	Above average frequency of requests within a given duration Parameters such as IP addresses, HTTP Methods, HTTP Status Codes
NF information	NF ID, NF instance information such as average number of instances and peak number of instances
Counters	API invocations within a given duration

6.3.3 Evaluation

Collecting data in Table 6.3.2-2 above may help provide visibility of a DoS attack on APIs deployed by an O-RAN architecture element. Normal baseline levels of activity can be established through monitoring and collection of the aforementioned data, which may allow the detection of anomalous activity for resource utilization and API communications that may be indicative of a DoS attack. A unique ID is also assigned to the attack to provide easy reference inside a playbook to indicate what type of data may be useful within the context.

6.4 Solution #3: Continuous security monitoring for adversarial attacks on AI/ML models

6.4.1 Introduction

The use of AI/ML models in O-RAN architecture elements introduces new security risks, particularly the threats of adversarial attacks and data drift. Also, the lack of transparency and explainability in AI/ML models used in O-RAN architecture elements can make it challenging to detect and respond to potential security threats. To mitigate these risks, continuous security monitoring of AI/ML models and datasets is essential.

6.4.2 Solution details

To address the key issues of adversarial attacks on AI/ML models, Model Explainability and Transparency and Model and Data Drift, the following requirements are proposed:

- **Continuous Monitoring of AI/ML Models:** Implement real-time monitoring of AI/ML models to detect anomalies and potential security threats. This can be achieved through the use of machine learning-based anomaly detection techniques, such as One-Class SVM [i.16] or Autoencoders [i.17].

ML-based anomaly detection technique	Explanation
One-Class SVM	One-class Support Vector Machines are a type of outlier detection method, using ML techniques to automatically define a boundary to detect outliers in a given input set. [i.16]
Autoencoders	An Autoencoder is a neural network used for unsupervised learning, trained to reconstruct its input data out of a previously learned compressed form of it. [i.17]

- **Model Performance Metrics:** Continuously monitor model performance metrics to detect potential drift or degradation in model performance, such as:

Metric	Explanation
--------	-------------

accuracy	number of correct predictions divided by the total number of predictions
precision	ratio of true positives and total positives predicted

6.4.3 Evaluation

The effectiveness of this solution can be evaluated through the following metrics:

- **Detection Rate:** Measure the number of adversarial attacks detected through continuous monitoring.
- **False Positive Rate:** Measure the number of false positives generated by the monitoring system.

6.5 Solution #4: Continuous security monitoring for AI/ML-related data integrity and confidentiality

6.5.1 Introduction

The collection, storage, and transmission of large datasets for AI/ML models in O-RAN architecture elements introduce risks related to data integrity and confidentiality. To mitigate this risk, continuous security monitoring of data storage and transmission protocols is essential to detect and prevent unauthorized access or manipulation.

6.5.2 Solution details

To address the key issue of AI/ML-related data integrity and confidentiality, the following requirements are proposed:

- **Data Integrity Checks:** Continuously monitor data integrity to detect potential data manipulation or tampering.
- **Intrusion Detection:** Continuously monitor AI/ML- related system parameters to detect potential security threats or breaches.

6.5.3 Evaluation

The effectiveness of this solution can be evaluated through the following metrics:

- **Data breach detection:** Measure the number of potential data breaches detected through continuous monitoring.
- **Data manipulation or tampering detection:** measure the number of data manipulations detected through continuous monitoring.

6.6 Solution #5: Continuous security monitoring for software delivery

6.6.1 Introduction

The software delivery process is a critical component of the O-RAN architecture elements security, as it is susceptible to malicious actors who may inject harmful code or introduce vulnerabilities. While the O-RAN specification does not comprehensively cover software delivery, it provides essential security requirements that form the foundation for addressing this issue. This clause proposes a solution to enhance the security of software delivery through continuous monitoring, leveraging existing O-RAN security measures to ensure the integrity and authenticity of software packages.

6.6.2 Solution details

To mitigate the risks associated with compromised software delivery, the following measures are proposed:

Continuous security monitoring of software validation during onboarding:

- Provide real-time monitoring data on functions that verify the digital signatures and integrity of software packages, ensuring compliance with O-RAN security requirements (e.g., REQ-SEC-ALM-PKG-2, REQ-SEC-ALM-PKG-4).

Table 6.6.2-1 - Data for software validation during onboarding

ID	Description	Examples
AppPackID	Unique identification for an Application package	
SignatureValidationResult	Result of the signature verification	successful unsuccessful
IntegrityValidationResult	Result of the integrity verification	successful unsuccessful

Continuous security monitoring of vulnerability management:

- Monitor the reporting of vulnerabilities discovered during testing, adhering to O-RAN's vulnerability management requirements (e.g., REQ-SEC-ALM-PKG-7B).

Table 6.6.2-2 Data for software vulnerability management

ID	Description	Examples
AppPackID	Unique identification for an Application package	
VulnerabilitiesDiscovered	A list of vulnerabilities discovered for an ApplicationPackage	CVE number

6.6.3 Evaluation

The effectiveness of this solution can be evaluated through the following metrics:

- **Detection Rate:** Measure the number of adversarial attacks detected through continuous monitoring.
- **False Positive Rate:** Measure the number of false positives generated by the monitoring system.

6.7 Solution #6: Continuous security monitoring for authentication attacks

6.7.1 Introduction

Authentication related attacks need to be mitigated after sufficient monitoring on the O-RAN NFs and interfaces where authentication takes place.

6.7.2 Solution details

For monitoring authentication related attacks the following data could be collected as prescribed in [i.11]. For example, authentication logs can be reviewed to ensure that mechanisms such as enforcement of MFA are functioning as intended.

Table 6.7.2-1 - Security logs for authentication attacks

Security logs		
Description	ID	Example
Successful and unsuccessful cases	Successful_authentication Unsuccessful_authentication	Operation= Unsuccessful_authentication, userid='1234',etc
Security logs related to failure in multi factor authentication	Failure in multi authentication factor_log	Failure of password and fingerprint
Weak related or missing or not updated authentication related policies like password policy	Authentication_policy_not_updated	Policy not updated since x days
Security logs related to accessing of private keys	Private_key_access	Access to private keys attempted
Security logs related to accessing of certificates with out proper passphrase	Certificate_passphrase_attempted	Passphrase for certificate is wrong

Table 6.7.2-2 - Security counters for authentication attacks

Security related counters		
Description	ID	Example
Counter related to number of sessions exceeded	User_session_counter	
Counter for number of unauthenticated attempts	Authentication_failure_counter	
Counter related number of failed password attempts in time period	Password_failure_counter_in_time_period	

Table 6.7.2-3 - Security alarms for authentication attacks

Security related alarm		
Description	ID	Example
Alarms for default password unchanged	Alarm_default_password_unchanged	Alarm attribute updated with 'Default password unchanged'

Table 6.7.2-4 – Other security related data for authentication attacks

Other security related data		
Description	ID	Example

Time of day for authentication access to O-RAN architecture elements		
Time of day related to brute-force attempt		
Location	Could be derived from the IP address or inventory.	

6.7.3 Evaluation

The effectiveness of this solution can be evaluated through the data definition for the solutions above and collection of logs, alarms, counters related to the authentication attacks as part of key issue #4.

6.8 Solution #7: Continuous security monitoring for authorization attacks

6.8.1 Introduction

Authorization related attacks need to be mitigated through sufficient monitoring on the O-RAN NFs and interfaces where authorization takes place.

6.8.2 Solution details

For monitoring authorization related attacks, the following data could be collected as in [i.11].

Table 6.8.2-1 - Security logs for authorization attacks

Security logs		
Description	ID	Example
Security logs with authorization failures	Unauthorized access to O-RAN NF	Unauthorized access for user
Security logs with attempt to modify data without authorized access rights	Manipulation of data_attempted	
Logs related to privilege escalation	Misconfiguration	
Security logs indicating the excessive rights for long periods of time	Violation of the principle of least privilege	

Table 6.8.2-2 - Security alarms for authorization attacks

Security alarm		
Description	ID	Example
Alarm related to privilege escalation		

Table 6.8.2-3 - Security counters for authorization attacks

Security counter		
Description	ID	Example
Counter related to number of permissions administered for a period of time		

Table 6.8.2-4 - Security related data for authorization attacks

Other security related data		
Description	ID	Example
Time of day for misconfiguration		
Time of day for violation of least privilege		

6.8.3 Evaluation

The effectiveness of this solution can be evaluated through the data definition for the solutions above and collection of logs, alarms, counters related to the authorization attacks as part of key issue #6.

6.9 Solution #8: Continuous security monitoring for cloud attacks related to lateral movement

6.9.1 Introduction

O-Cloud infrastructure and the applications deployed on it are prone to attacks related to lateral movement of the attacker. This can be achieved through techniques such as remote execution, privileged account escalation, and network-level exploitation. The goal of lateral movement is to maintain a persistent presence within the network and to eventually achieve the attacker's objectives.

6.9.2 Solution details

Preventing lateral movement attacks is a critical component of an effective cybersecurity strategy. There are several measures that can be used to proactively detect lateral movement on cloud infrastructure and the applications deployed on it, including the security logs, counters and alarms listed in the tables below:

Table 6.9.2-1 - Security logs for cloud attacks related to lateral movement

Security Logs		
ID	Description	Example
Access_logs	Access Patterns: Monitoring of user access to NFs and cloud resources.	Eg: number of times of access to a NF Time of day to access the NF
Anomalous behaviour_log	Anomalous Behaviour Detection: Abnormal system calls or API usage.	eg: out of order API invocation
firewall_logs	Firewall Logs: Denied connections and unusual access attempts.	eg: Authentication_failure Time of access
Security logs	Audit Logs: User access and privilege escalation events, including SSH and API logins.	eg: user access logs privilege escalation logs SSH logins API logins
Interface_logs	Interface Information: Interfaces exposed by the service (Nmap scan)	eg: details of interface/service exposed by NF

Table 6.9.2-2 - Security counters for cloud attacks related to lateral movement

Security Counters		
ID	Description	Example
Access_Counter	Number of times a user has accessed a NFs and/or cloud resources. Could be used for a access pattern	Eg: number of times of access to a NF
Process_activity_counter	Process Activity: High CPU/memory-consuming processes or unexpected background tasks.	eg: CPU_Usage memory usage of NF

Table 6.9.2-3 - Security alarms for cloud attacks related to lateral movement

Security Alarm		
ID	Description	Example
Process_activity_alarm	Process Activity: High CPU/memory-consuming processes or unexpected background tasks.	eg:

		Alarm with probable cause indicating high memory consumption
Intrusion_Detection_Alarm	Intrusion Detection Alerts: Suspicious patterns identified by IDS/IPS systems.	eg: suspicious activity alarm from IDS NF

6.9.3 Evaluation

The effectiveness of this solution can be evaluated through the data definition and collection of the metrics related to the lateral movement detection for cloud attacks.

6.10 Solution #9: Detection and prediction of DoS attacks due to packet flooding using Density Based Clustering

6.10.1 Introduction

This solution proposes a DDoS Attack Detection and Prevention Function collecting data from all O-RAN architecture elements to determine whether a DoS attack due to packet flooding might be occurring.

This solution is based on covering the threats related to DoS attacks as well as the data gathered with respect to DoS attacks due to packet flooding from Key Issue #1 and solutions #1 and #2.

The DoS Attack Prevention and Detection Function uses Density Based Clustering to cluster the data it receives from each O-RAN architecture element to determine if a DoS attack due to packet flooding is occurring. Density Based Clustering (DBC) is used to detect clusters of concentrated points that are separated by sparse or empty areas; points that are not part of a cluster are labeled as noise.

6.10.2 Solution details

Implementations of the DDoS Detection and Prevention Function may vary, but this function may include the following functionalities in order to mitigate the risks detailed in Key Issue #1, in addition to solution #1, #2:

- The DDoS Attack Detection and Prevention Function should collect data from all O-RAN architecture elements (O-RU, O-CU, and O-DU) to detect DDoS attacks across the entire network.
 - The data that each architecture element provides can include the architecture element identification information, number of clusters that are above a configured threshold, and origins for the largest number of packets.
- Each architecture element applies a Density Based Clustering algorithm to the packets it receives
 - The Density Based Clustering algorithm will provide information about the most dense/populated clusters
 - Dense clusters with a burst of packets can be indicative of a DDoS attack.

Figure 6.10-1 illustrates a depiction of a burst of packets, which is a sequence of a large number of packets surrounded by sparsely populated areas.

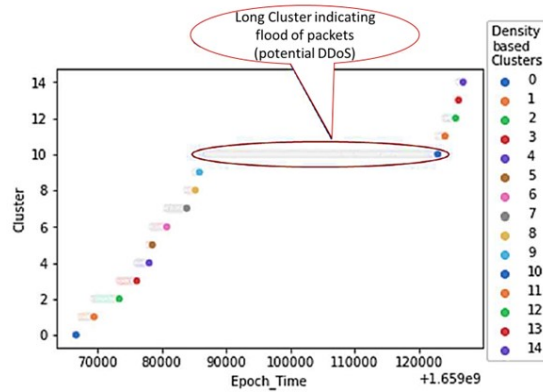


Figure 6.10-1 - Diagram illustrating burst of packets

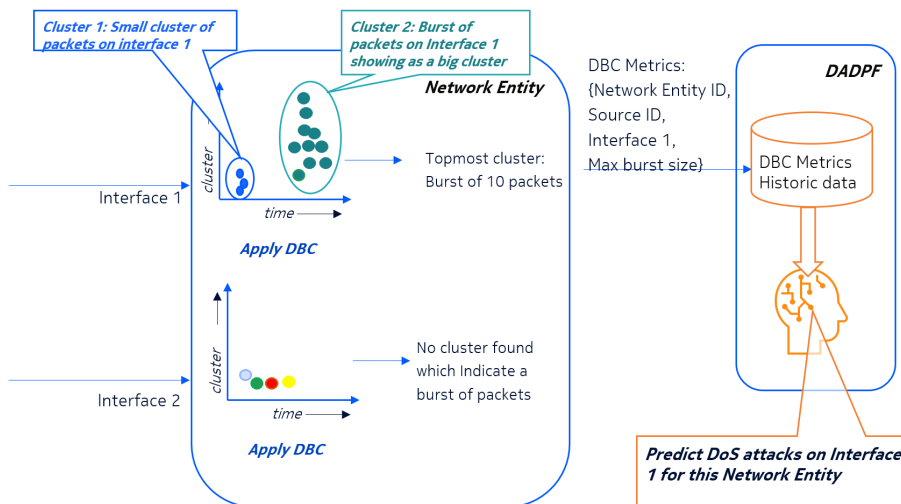


Figure 6.10-2 - Overall system level view of DBC implementation

In Figure 6.10-2, DBC Metrics can be cluster ID, number of packets, and top sources for the clusters crossing a configured threshold. DADPF is an analytics function that uses DBC metrics received from various O-RAN architecture elements, correlates DBC metrics, and enables prediction of DoS attacks to proactively mitigate risk.

Table 6.10.2-1 - Example description of clusters exceeding threshold

Cluster	Packet Count	Top Source IPs Exceeding Threshold
1	21850	[192.168.0.7, 192.168.0.10]
2	605	[192.168.0.1, 192.168.0.9]

3	11878	[192.168.0.8, 192.168.0.10]
4	15920	[192.168.0.7, 192.168.0.8]

Table 6.10.2-1 depicts an example of summary statistics that DBC provides that shows the different clusters detected and source IP addresses that have the most number of clusters that exceed the configured threshold. If a cluster exceeds the threshold, that indicates that the cluster is an example of a DoS caused by packet flooding.

Each architecture element calculates DBC metrics based on data it collects as indicated in solution #1.

DBC Metrics can be transferred from the O-RAN architecture element to an NF that analyses DBC metrics.

6.10.3 Evaluation

This solution provides details of a possible implementation option to collect and analyse data collected from each architecture element in O-RAN to detect and prevent DoS attacks. This solution also enforces the requirement from Key Issue 1 regarding obtaining data from all O-RAN architecture elements.

7 Conclusions

7.1 Key issue to solution mapping

This document currently contains 18 key issues. The solutions are listed here for reference, followed by a mapping of the proposed solutions to the key issues in Table 6.10.3-1.**Error! Reference source not found..**

- Solution #1: Data required for detecting DoS attacks due to flooding
- Solution #2: Data required to detect API security risks (DoS through resource consumption)
- Solution #3: Continuous security monitoring for adversarial attacks on AI/ML models
- Solution #4: Continuous security monitoring for AI/ML-related data integrity and confidentiality
- Solution #5: Continuous security monitoring for software delivery
- Solution #6: Continuous security monitoring for authentication attacks
- Solution #7: Continuous security monitoring for authorization attacks
- Solution #8: Continuous security monitoring for cloud attacks related to lateral movement

Table 6.10.3-1 - Mapping of key issues to Solutions

Key issue	Sol # 1	Sol n#2	Sol #3	Sol #4	Sol #5	Sol #6	Sol #7	Sol #8	Sol #9
KI 1	X								X
KI 2		X							X
KI 3								X	
KI 4						X			
KI 5									
KI 6							X		
KI 7									
KI 8									
KI 9									
KI 10									
KI 11					X				
KI 12									
KI 13			X						
KI 14				X					
KI 15			X						

Key issue	Sol # 1	Sol n#2	Sol #3	Sol #4	Sol #5	Sol #6	Sol #7	Sol #8	Sol #9
KI 16									
KI 17									
KI 18									

7.2 Recommendations

This clause will contain recommendations concluded from the study.

Annex:

Change history/Change request (history)

Date	Revision	Description
2024.09.05	00.03	Skeleton TR approved
2024.10.03	00.04	Merged in approved CR NOK0183 and NOK 0184
2024.10.30	00.05	Merged in approved CRs NOK0192, NOK0193, NOK0200, NOK0199
2024.12.12	00.06	Merged in approved CRs MTR0123, NOK0205, NOK0211, MTR0125
2025.02.06	00.07	Merged in approved CRs MTR0104, MTR0124, MTR0128, NOK0204, NOK0214, NOK0215, NOK0218, NOK0219, NOK0224, NOK0225, NOK0226, NOK0227
2025.02.26	00.08	Merged in approved CRs NOK0229, NOK0230, NOK0247, NOK0250, NOK0248, NOK0249
2025.03.06	00.09	Merged in approved CRs NOK0261, NOK0262, NOK0258, NOK0252, NOK0267